컴퓨터 소프트웨어 공학과 20240900 강우석

PWA 기반 O2O 플랫폼의 프론트엔드 편의성 및 보안 기술 탐구

프로젝트명: Dicha Coffee (O2O 커스텀 로스팅 커피 플랫폼)

DONGYANG MIRAE UNIVERSITY • 동양미래대학교 •

목차

1. 서론
   1.1) 프로젝트에서 나의 역할
   1.2) 프로젝트에서 내가 탐구할 기술
   1.3) 프로젝트 구축에서 탐구 기술들이 필요한 이유
2. 본론
   2.1) 편의성 & O2O 융합 기술
   2.1.1) WebRTC 기반 모바일 카메라 제어 및 QR 스캐너
   2.1.2) Web Push Notifications API (웹 푸시 알림)
   2.2) 프론트엔드 보안 기술
   2.2.1) HttpOnly 쿠키와 안전한 토큰 관리
3. 결론
   3.1) 프론트엔드 기술을 조사·연구하면서 알게 된 사실
   3.2) 프로젝트에 조사 기술 적용 방안
4. 참고자료

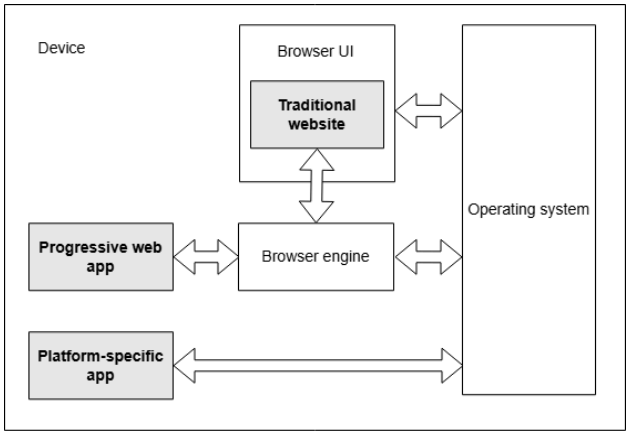
1. 서론

1.1) 프로젝트에서 나의 역할

'Dicha Coffee' 프로젝트는 온·오프라인을 연계하여 커스텀 로스팅 원두를 제공하는 O2O(Online to Offline) 플랫폼이다. 본인은 이 프로젝트에서 프론트엔드 개발 파트를 담당하며, React.js와 Zustand 등의 모던 웹 기술을 활용해 UI/UX를 구현하고 모바일 환경에 최적화된 클라이언트 아키텍처를 설계하는 역할을 맡고 있다.

1.2) 프로젝트에서 내가 탐구할 기술

웹 브라우저 환경에서 네이티브 앱과 유사한 사용자 경험을 제공하기 위한 PWA(Progressive Web App) 기술을 중점적으로 탐구한다. 또 오프라인 매장 특성상 인파가 몰려 네트워크가 불안정하거나 끊기는 상황을 대비하여여 PWA의 Service Worker를 활용해 핵심 UI리소스(QR코드 등)을 브라우저 Cache Storage에 사전 저장(Pre-caching)하는 부분을 고려하고 또 세부적으로는 오프라인 매장과의 상호작용을 위한 WebRTC 기반 카메라 제어 기술, 사용자 리텐션을 높이기 위한 Web Push Notifications API, 그리고 클라이언트 보안 강화를 위한 HttpOnly 쿠키 기반의 안전한 토큰 관리 기술을 탐구한다.



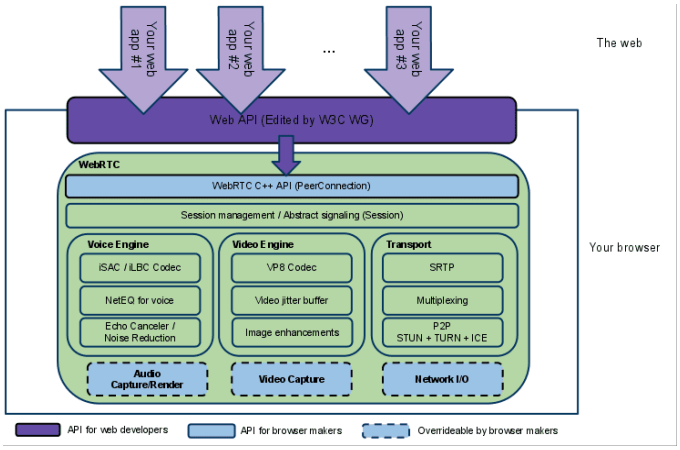
PWA(Progressive Web App) 기술

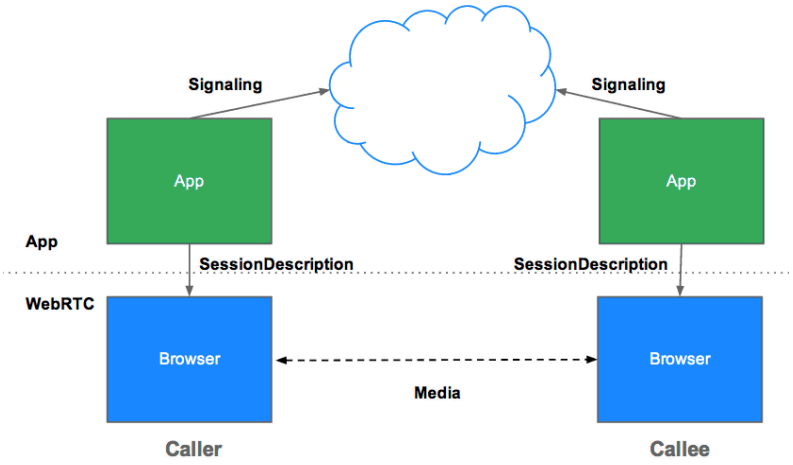
1.3) 프로젝트 구축에서 탐구 기술들이 필요한 이유

Dicha Coffee는 단순한 온라인 쇼핑몰이 아니라, 온라인의 '커스텀 로스팅 레시피'와 오프라인 매장이 연결되어야 하는 O2O 서비스다. 사용자가 네이티브 앱을 설치하는 번거로움 없이도 매장에서 즉각적으로 QR 코드를 스캔하고, 브라우저가 닫힌 상태에서도 구독 원두 발송 알림을 받기 위해서는 PWA의 핵심 API들이 필수적으로 요구된다. 또한, 사용자 개인의 취향 데이터와 결제 및 구독 정보를 다루는 만큼 프론트엔드 단에서의 토큰 탈취를 방지하는 보안 설계가 뒷받침되어야 한다.

2. 본론

2.1) 편의성 & O2O 융합 기술

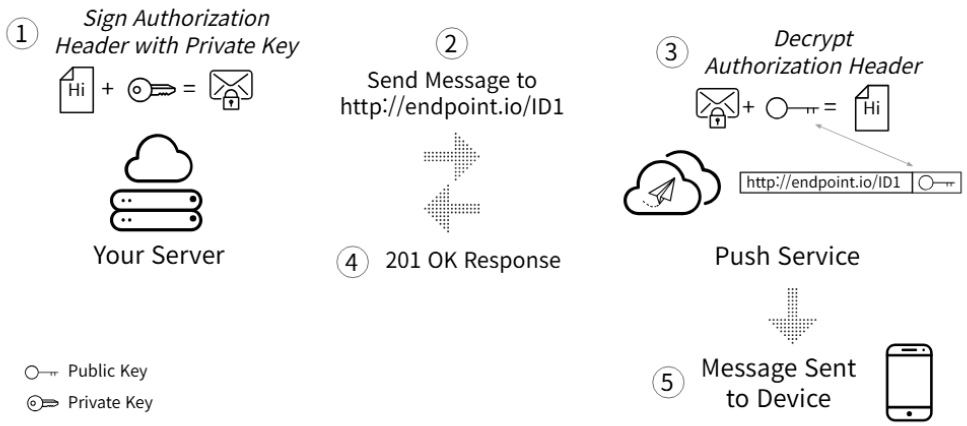




2.1.1) WebRTC 기반 모바일 카메라 제어 및 QR 스캐너 (HTML5 Barcode API)

- 작동 원리 및 탐구 이유: Dicha Coffee의 '나의 블렌드' 기능은 오프라인 매장에서 생성된 커스텀 블렌드를 온라인으로 가져오거나, 반대로 앱의 레시피를 매장에 전달할 때 QR 코드를 매개체로 사용한다. 이를 위해 HTML5의 WebRTC(Web Real-Time Communication) 및 `getUserMedia` API를 활용한다.

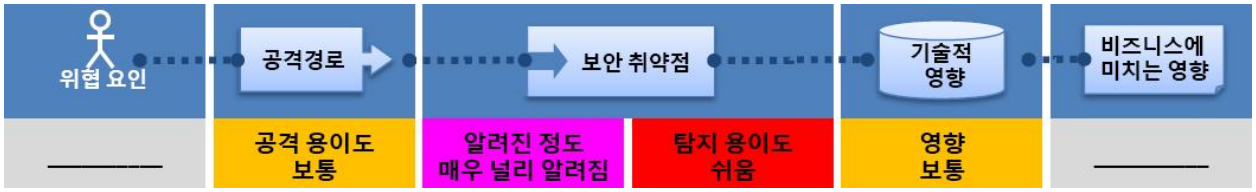
- 구현 및 기대 효과**:** 사용자는 기기에 별도의 스캐너 앱을 설치할 필요 없이, 브라우저의 카메라 접근 권한만으로 즉각적인 O2O 상호작용이 가능해진다. 이는 오프라인 오더와 온라인 레시피 관리 사이의 간극을 획기적으로 줄여준다.
- 보완할점
  사용자가 카메라 접근 권한을 거부하거나 기기 오류로 스캔이 불가능할 경우를 대비하여, 직접 핀 번호나 예약 번호를 입력할 수 있는 대체**(Fallback) UI**를 설계하여 사용자 경험(UX)의 단절을 막을것입니다.



2.1.2) Web Push Notifications API (웹 푸시 알림)

- 작동 원리 및 탐구 이유**:** 정기적인 커피 구독 서비스('홈 구독', '오피스 구독')와 로스팅 진행 상태를 사용자에게 적시에 안내하기 위해 알림 기능이 필요하다. PWA의 핵심인 Service Worker를 활용하면 백그라운드 스크립트 실행이 가능해진다.
- 구현 및 기대 효과**:** 사용자가 웹 브라우저를 닫아둔 상태에서도 네이티브 OS(iOS, Android)의 알림 센터를 통해 푸시 알림을 받을 수 있다. "이번 주 구독 원두가 발송되었습니다"와 같은 개인화된 알림을 통해 서비스 재방문율을 크게 향상시킬 수 있다.
- 한계 및 보완할점: iOS에서는 '홈 화면에 추가(PWA 설치)'가 선행되어야 한다는 제약이 있다. 이를 해결하기 위해, 서비스 진입 시 사용자에게 '앱 설치 가이드'를 자연스럽게 띄워 홈 화면 추가를 유도한다.

2.2) 프론트엔드 보안 기술



2.2.1) HttpOnly 쿠키와 안전한 토큰 관리

- 작동 원리 및 탐구 이유**:** 사용자 로그인 유지 및 구독 관리를 위해 JWT(JSON Web Token)와 같은 인증 토큰을 클라이언트에 저장해야 한다. 이를 `localStorage`나 `sessionStorage`에 저장할 경우 자바스크립트를 통한 XSS(교차 사이트 스크립팅) 공격에 탈취당할 위험이 높다.
- 구현 및 기대 효과**:** 프론트엔드 코드에서 토큰에 직접 접근하지 못하도록, 서버에서 발급하는 쿠키에 `HttpOnly` 속성을 부여하여 통신하도록 설계한다.React.js 환경에서는 Axios 인터셉터(Interceptors)와 백엔드 API 서버의 미들웨어로 활용함으로써 클라이언트에서의 토큰 탈취를 차단하고 보안성을 높일 수 있다.

3. 결론

3.1) 프론트엔드 기술을 조사·연구하면서 알게 된 사실

과거에는 하드웨어 제어(카메라)나 백그라운드 푸시 알림을 구현하기 위해 반드시 안드로이드나 iOS 네이티브 앱 개발이 필수적이라고 생각했다. 하지만 WebRTC와 Service Worker 기반의 PWA 기술을 연구하면서, 모던 웹 기술만으로도 네이티브 앱에 준하는 편의성과 O2O 연결성을 충분히 구현할 수 있다는 사실을 알게 되었다.

3.2) 프로젝트에 조사 기술 적용 방안

기획 중인 Dicha Coffee 프로젝트의 개발 프로세스에 맞춰, 프로토타입 단계에서 PWA 기본 환경 설정(`manifest.json`, Service Worker)을 완료할 계획이다. 이후 본 개발 단계에서 WebRTC를 활용한 QR 스캐너 컴포넌트를 구현하고, 사용자 인증 인가 로직에 HttpOnly 쿠키 처리 방식을 적용하여 안정적이고 보안이 뛰어난 커스텀 로스팅 웹앱을 완성할 것이다.

4. 참고자료

- **MDN Web Docs:** WebRTC API (MediaDevices.getUserMedia) 공식 문서
- **MDN Web Docs:** Push API 및 Service Worker API 공식 문서
- https://web.dev/articles/webrtc-basics?hl=ko: 웹 애플리케이션과 사이트가 중간자 없이 브라우저 간에 오디오나 영상 미디어를 포착하고 마음대로 스트림할 뿐 아니라, 임의의 데이터도 교환할 수 있도록 하는 기술
- https://developer.mozilla.org/ko/docs/Web/API/Push_API :웹 앱이 활성 상태에 있는지 또는 현재 로드 중인지 여부와 관계없이 서버로부터 푸시 메시지를 수신할 수 있는 기능 , 이미지 출처 :https://incodom.kr/PWA/Web-Push-Notifications ,push-notifications-subscribing-a-use
- **Google web.dev:** Progressive Web Apps (PWA) 아키텍처 및 모범 사례 가이드
- https://developers.cafe24.com/app/front/app/develop/oauth/retoken , https://developers.kakao.com/docs/ko/kakaologin/common ,https://www.ibm.com/kr-ko/think/topics/oauth : OAuth 2.0과OAuth ,
- **OWASP (Open Web Application Security Project):** Cross Site Scripting (XSS) 방어 및 HttpOnly 쿠키 활용 가이드
- https://www.ahnlab.com/ko/contents/content-center/16698 : 보안 공격 이미지 사용
- https://developer.mozilla.org/ko/docs/Web/HTTP/Guides/Cookies :http 쿠키